

SGSI-UNCP

Metodología de Evaluación y Tratamiento de Riesgos de Seguridad de la Información

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Metodología de Evaluación y Tratamiento de Riesgos de Seguridad de la Información
 - 1.1 Objetivo
 - 1.2 Alcance
 - 1.3 Frecuencia de Evaluación
 - 1.4 Apetito de Riesgo
 - 1.5 Fases de la Metodología
 - 1.6 Documentos Relacionados

1. Metodología de Evaluación y Tratamiento de Riesgos de Seguridad de la Información

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Norma:** ISO/IEC 27001:2022 (Cláusulas 6.1.2, 6.1.3) e ISO 31000

1.1. Objetivo

Establecer el marco metodológico sistemático para identificar, analizar, evaluar y tratar los riesgos de seguridad de la información que puedan afectar la confidencialidad, integridad y disponibilidad de los activos de información de la UNCP, en cumplimiento de los requisitos de las Cláusulas 6.1.2 y 6.1.3 de la ISO/IEC 27001:2022 y los lineamientos del D.S. N.º 029-2021-PCM (Marco de Confianza Digital).

1.2. Alcance

Esta metodología se aplica a todos los procesos (estratégicos, misionales y de apoyo), sistemas de información (ERP ADESA, Campus Virtual Moodle 4.1, Microsoft 365, DSpace, SIGA/SIAF) e infraestructura tecnológica (servidores on-premise, Huawei Cloud, red de datos, equipos de usuario final) detallados en el alcance del SGSI de la UNCP (D-SGSI-02).

1.3. Frecuencia de Evaluación

La evaluación de riesgos se realizará en los siguientes escenarios:

- **Planificada:** Al menos una vez al año, como parte del ciclo PHVA del SGSI.
- **Extraordinaria:** Cuando ocurran cambios significativos en la infraestructura tecnológica (ej. migración a Huawei Cloud, implantación de un nuevo sistema core).
- **Reactiva:** Después de un incidente de seguridad grave (ej. brecha de datos confirmada, ataque ransomware con impacto operativo).
- **Proyectos:** Al implementar nuevos proyectos del PGTD (ej. PGTD-01 SGSI, Portal de Servicios Digitales, modernización del Data Center).

1.4. Apetito de Riesgo

La UNCP establece que su apetito de riesgo es **conservador** para los procesos misionales (formación, investigación, grados y títulos) y **moderado** para los procesos de apoyo. Esto implica:

- No se aceptan riesgos críticos (NR 13–16) sin acción inmediata.
- Los riesgos altos (NR 9–12) requieren tratamiento en un plazo máximo de 90 días.
- Los riesgos medios (NR 5–8) deben ser tratados en el plan anual de seguridad.
- Los riesgos bajos (NR 1–4) se aceptan formalmente y se monitorean.

1.5. Fases de la Metodología

1.5.1. Fase 1: Identificación de Activos

Se utiliza el **R-SGSI-01: Inventario de Activos de Información** como insumo base para listar todos los activos dentro del alcance del SGSI. Para cada activo se identifica:

- **Dueño del activo:** Responsable del activo (jefe de oficina, director de escuela, etc.).
- **Tipo de activo:** Información digital, información física, software, hardware, servicios, personas, redes.
- **Ubicación:** Física (sede, oficina) o lógica (servidor, cloud, repositorio).

- **Clasificación:** Según la política D-SGSI-03 (Confidencial, Interna Restringida, Interna, Pública).

1.5.2. Fase 2: Identificación de Riesgos

Para cada activo, se identifican los riesgos considerando:

- **Vulnerabilidades:** Debilidades del activo (ej. software desactualizado, falta de cifrado, ausencia de copias de seguridad, personal sin capacitación).
- **Amenazas:** Causas potenciales de un incidente (ej. ataque ransomware, falla eléctrica, error humano, desastre natural).

Las fuentes de amenazas se clasifican en:

Tipo	Ejemplos UNCP
Ambientales / Físicas	Sismos (Huancayo, zona sísmica), cortes eléctricos, inundaciones, incendios
Tecnológicas	Fallas de hardware, caída de enlace de red, corrupción de base de datos, obsolescencia de software
Humanas (intencionales)	Ataques de phishing, ransomware, accesos no autorizados, fraude interno, sabotaje
Humanas (no intencionales)	Errores de configuración, borrado accidental, pérdida de dispositivos, mala praxis operativa
Legales / Regulatorias	Cambios en la Ley N.º 29733, nuevas disposiciones SUNEDU, incumplimiento de cláusulas contractuales

1.5.3. Fase 3: Análisis de Riesgos

El análisis se realiza calculando el **Nivel de Riesgo (NR)** mediante la combinación de la **Ocurrencia (O)** y el **Impacto (I)**.

Fórmula: $NR = O \times I$

Escala de Ocurrencia (Probabilidad)

Valor	Nivel	Descripción
1	Baja	Improbable que la amenaza se materialice (1 vez cada 5 años o más)
2	Media	Posible que la amenaza se materialice (1 vez al año)
3	Alta	Muy probable que la amenaza se materialice (1 vez al mes o trimestre)
4	Muy Alta	Casi seguro que la amenaza se materialice (diariamente o semanalmente)

Escala de Impacto (Consecuencia) Se evalúa el impacto sobre la Confidencialidad, Integridad y Disponibilidad (CID). Se toma el valor más alto de los tres.

Valor	Nivel	Descripción (Contexto UNCP)
1	Menor	Interrupción breve de servicios no críticos (< 1 hora). Sin pérdida de datos. Sin impacto reputacional.
2	Moderado	Interrupción temporal del ERP o Campus Virtual (< 4 horas). Afectación a procesos internos sin impacto a estudiantes.
3	Significativo	Fuga de datos personales (Ley N.º 29733), interrupción de matrícula (> 4 horas), impacto a la imagen institucional.
4	Catastrófico	Pérdida total de bases de datos críticas, paralización prolongada (> 24 horas), sanción de SUNEDU o Autoridad Nacional de Protección de Datos Personales.

1.5.4. Fase 4: Evaluación de Riesgos (Matriz de Calificación)

El **Nivel de Riesgo (NR)** se determina mediante la matriz siguiente:

Ocurrencia Impacto	Menor (1)	Moderado (2)	Significativo (3)	Catastrófico (4)
Muy Alta (4)	4	8	12	16
Alta (3)	3	6	9	12
Media (2)	2	4	6	8
Baja (1)	1	2	3	4

Nivel de Riesgo y Acción Requerida

Rango NR	Nivel	Acción Requerida
1 – 4	Bajo	Riesgo Aceptable. Mantener controles actuales. Monitoreo periódico.
5 – 8	Medio	Requiere tratamiento planificado en el plan anual de seguridad.
9 – 12	Alto	Requiere tratamiento urgente (máximo 90 días). Reportar al CGD.
13 – 16	Crítico	Intolerable. Acción inmediata por parte del Comité de Gobierno Digital.

Criterio de Aceptación del Riesgo: La UNCP acepta convivir con riesgos cuyo NR sea **Bajo (1–4)**. Cualquier riesgo con NR ≥ 5 debe tener un plan de tratamiento documentado en R-SGSI-02.

1.5.5. Fase 5: Tratamiento de Riesgos

Para cada riesgo no aceptable (NR ≥ 5), el dueño del riesgo selecciona una opción de tratamiento:

1. **Mitigar (Modificar):** Aplicar controles del Anexo A de ISO/IEC 27001:2022 para reducir la probabilidad o el impacto. Es la opción más común.
2. **Evitar (Evadir):** Eliminar la causa del riesgo, por ejemplo, descontinuoando un proceso, desactivando un sistema vulnerable o reemplazando un software obsoleto.
3. **Transferir (Compartir):** Trasladar el impacto financiero o de gestión a un tercero (ej. seguro cibernético, SLA con proveedor cloud, outsourcing de seguridad gestionada).
4. **Aceptar (Retener):** Aceptar el riesgo conscientemente y por escrito, solo si el costo de mitigación supera el impacto potencial y es aprobado formalmente por el Rectorado.

1.5.6. Fase 6: Plan de Tratamiento (R-SGSI-02)

Cada riesgo tratado se documenta en el **R-SGSI-02: Plan de Tratamiento de Riesgos**, que incluye:

- Riesgo identificado y NR actual
- Opción de tratamiento seleccionada
- Controles del Anexo A aplicables
- Responsable de implementación
- Fecha límite y recursos asignados
- NR residual esperado después del tratamiento

1.5.7. Fase 7: Declaración de Aplicabilidad (SoA)

Los controles seleccionados en la fase de mitigación se documentan en el **D-SGSI-05: Declaración de Aplicabilidad (SoA)**, justificando:

- **Inclusión:** Por qué el control es aplicable.
- **Exclusión:** Si un control del Anexo A no se aplica, justificar formalmente la exclusión (ej. “No aplica porque la UNCP no realiza procesamiento de pagos con tarjetas de crédito”).
- **Estado de implementación:** Implementado, parcialmente implementado, planificado, no implementado.

1.5.8. Fase 8: Monitoreo y Revisión

Los riesgos se revisan periódicamente para asegurar que:

- Los tratamientos implementados son eficaces.
- No han surgido nuevos riesgos o amenazas.
- El contexto organizacional no ha cambiado significativamente.
- Los riesgos aceptados siguen siendo aceptables.

El monitoreo se integra en las auditorías internas anuales y en la Revisión por la Dirección (Cláusula 9.3).

1.6. Documentos Relacionados

- R-SGSI-01: Matriz de Evaluación y Tratamiento de Riesgos (Plantilla)
- R-SGSI-02: Plan de Tratamiento de Riesgos
- D-SGSI-05: Declaración de Aplicabilidad (SoA)
- D-SGSI-02: Alcance del SGSI
- D-SGSI-03: Política General de Seguridad de la Información
- ISO 31000: Gestión del Riesgo – Directrices
- ISO/IEC 27005: Gestión del Riesgo en Seguridad de la Información